

Information Systems Security

Threat Modelling and Scoping an Information
System

Learning Outcomes

By the end of this lecture, students should be able to:

- 1. Define** threat modelling and explain its importance in information systems security.
- 2. Explain** the relationship between threat modelling, risk assessment and the Software Development Life Cycle (SDLC).
- 3. Identify** the major components required to scope an information system for threat modelling.

Introduction to Threat Modelling

- **Threat modelling** is a structured process used to understand a system from a security perspective, identify what could go wrong, and determine appropriate security controls.
- OWASP describes threat modelling as a way of identifying, communicating and understanding threats and mitigations in the context of protecting something valuable. It can be applied to applications, networks, distributed systems, IoT devices and business processes.

System → Assets → Threats → Vulnerabilities → Risk → Countermeasures

- Threat modelling asks: How could an attacker compromise system, and what can we do about it?
- OWASP stands for the Open Worldwide Application Security Project

Why is Threat Modelling Important?

- Traditional security testing often asks: "Is there a vulnerability in the system?"
- Threat modelling asks a broader question: "What could go wrong with this system, how could it happen, and what should we do about it?"
- This difference is important because threat modelling can identify security problems **before the software is implemented**.
- OWASP recommends integrating threat modelling into the SDLC rather than treating it as a one-time activity. It is most useful when performed early enough for security findings to influence system design.

Benefits

- Identifies security weaknesses early.
- Reduces the cost of fixing design flaws.
- Improves security requirements.
- Helps developers understand attack scenarios.
- Supports risk-based security decisions.
- Helps identify appropriate security controls.
- Supports security testing.
- Improves communication between developers, security teams and management.
- Helps protect business-critical assets.

Threat Modelling in the SDLC

- Threat modelling should not be considered only an activity performed after software development.
- It can be incorporated throughout the SDLC.
- The earlier a design weakness is discovered, the easier and cheaper it is generally to address.

SDLC Stage	Threat Modelling Activity
Requirements	Identify security requirements and important assets
Architecture	Identify components, data flows and trust boundaries
Design	Identify potential threats and attack paths
Development	Review security assumptions and implementation
Testing	Develop security test cases
Deployment	Review infrastructure and external dependencies
Operations	Update threat model when system changes

OWASP Threat Modelling Process

- The OWASP historical process divides threat modelling into four major steps:
- **Step 1 – Scope Your Work**
 - Understand what is being protected and how the system works.
- **Step 2 – Determine Threats**
 - Identify what could go wrong.
- **Step 3 – Determine Countermeasures and Mitigation**
 - Determine how identified threats should be addressed.
- **Step 4 – Assess Your Work**
 - Evaluate whether the threat modelling exercise was sufficiently complete.
- The current OWASP project expresses essentially the same thinking through four questions:
 1. What are we working on?
 2. What can go wrong?
 3. What are we going to do about it?
 4. Did we do a good enough job?

Scope Your Work

- Understand the system before attempting to identify its threats.
- The **scope** defines what part of the system is included in the threat modelling exercise.
- For example, suppose a university operates:
 - Student portal
 - Learning Management System
 - Email system
 - Finance system
 - HR system
 - Library system
 - Wi-Fi infrastructure
- A threat modelling exercise might focus only on: Library system

Defining the System Boundary

- A **system boundary** determines what is:
 - Inside the system : Web Server, Database Authentication Service, API
 - Outside the system: Students, Internet, Payment Gateway, Cloud services
- The threat modeller must understand:
 - Where users interact with the system.
 - Where data enters.
 - Where data is processed.
 - Where data is stored.
 - Where data leaves.
 - Where trust changes occur.

Threat Model Information

- OWASP's example threat model begins by documenting basic information about the application. This provides context for the assessment.
- **Example**
- **Application:** University Student Portal
Version: 2.0
Purpose: Online student registration and academic services
Users: Students, lecturers, administrators
Owner: ICT Department
Participants: Developers, system administrator, security officer
Reviewer: IT Security Manager

Entry Points

- An **entry point** is an interface through which an attacker or user can interact with the application or provide data.
- Entry points show where data enters the system (i.e. input fields, methods) and exit points are where it leaves the system (i.e. dynamic output, methods), respectively. Entry and exit points define a trust boundary (see Trust Levels).
- OWASP defines entry points as interfaces through which potential attackers can interact with an application or supply it with data.
- **Examples**
 - Login page
 - Registration form
 - Search box
 - REST API
 - File upload
 - Web service
 - Mobile application
 - Network port
 - Email interface
 - Administrative console

Entry point Example

- The login page is an **entry point**
- Potential threats include:
 - Brute-force attacks
 - Credential stuffing
 - SQL injection
- https://owasp.org/www-community/Threat_Modeling_Process?utm_source=chatgpt.com#trust-levels

Entry point Example

ID	Name	Description	Trust Levels
1	HTTPS Port	The college library website will be only be accessible via TLS. All pages within the college library website are layered on this entry point.	(1) Anonymous Web User
			(2) User with Valid Login Credentials
			(3) User with Invalid Login Credentials
			(4) Librarian
1.1	Library Main Page	The splash page for the college library website is the entry point for all users.	(1) Anonymous Web User
			(2) User with Valid Login Credentials
			(3) User with Invalid Login Credentials
			(4) Librarian
1.2	Login Page	Students, faculty members and librarians must log in to the college library website before they can carry out any of the use cases.	(1) Anonymous Web User
			(2) User with Login Credentials
			(3) User with Invalid Login Credentials
			(4) Librarian
1.2.1	Login Function	The login function accepts user supplied credentials and compares them with those in the database.	(2) User with Valid Login Credentials
			(3) User with Invalid Login Credentials
			(4) Librarian
1.3	Search Entry Page	The page used to enter a search query.	(2) User with Valid Login Credentials
			(4) Librarian

Exit Points

- Exit points might prove useful when attacking the client: for example, cross-site-scripting vulnerabilities and information disclosure vulnerabilities both require an exit point for the attack to complete.
- An **exit point** represents where data or information leaves a system or component.

-

Entry Point	Exit Point
Data enters system	Data leaves system
Login form	Web response
File upload	File download
API request	API response
Search query	Search results
User input	Generated report

Assets

- An **asset** is something valuable that needs protection.
- OWASP notes that assets can include physical or abstract things and can represent things an attacker wants or something that must be protected.
- **Information assets**
 - Passwords
 - Student records
 - Credit-card information
 - Examination results
 - Personal data
 - Research data
 - Intellectual property
- **System assets**
 - Database
 - Application server
 - Authentication server
 - Network infrastructure
 - Source code
- **Business assets**
 - Reputation
 - Availability of services
 - Financial resources
 - Customer trust

Asset Classification

Asset	Example	Security Concern
Personal data	Student address	Confidentiality
Password	User credentials	Confidentiality
Examination result	Grade	Integrity
Student portal	Online service	Availability
Source code	Application code	Confidentiality/Integrity
Database	Student records	CIA
Reputation	University reputation	Integrity/Availability

Trust Levels

- A **trust level** represents the degree of access or privilege granted to an entity.
- Different users should not automatically have the same level of trust.
- Trust generally increases as privileges increase.

Level	User	Privileges
T0	Anonymous Internet User	Public information
T1	Authenticated Student	Own academic information
T2	Lecturer	Student academic records for assigned courses
T3	Administrator	Administrative operations
T4	Database Administrator	Database management

Normal Use Case vs Misuse Case

Normal Use Case	Misuse Case
Student logs in	Attacker steals credentials
Student registers course	Attacker registers on behalf of student
Lecturer enters grades	Unauthorized user modifies grades
Administrator creates account	Attacker creates privileged account
User uploads document	Attacker uploads malicious file

Threat Modeling - STRIDE

- A threat mnemonic such as STRIDE is useful in the identification of threats by prompting us to think about attacker steps such as:
 - **S**poofing
 - **T**ampering
 - **R**epudiation
 - **I**nformation Disclosure
 - **D**enial of Service
 - **E**levation of Privilege
- Threat modelling requires thinking like an attacker.

STRIDE Connection

STRIDE

S – Spoofing

T – Tampering

R – Repudiation

I – Information Disclosure

D – Denial of Service

E – Elevation of Privilege

Threat

Pretending to be another user

Modifying data

Denying an action

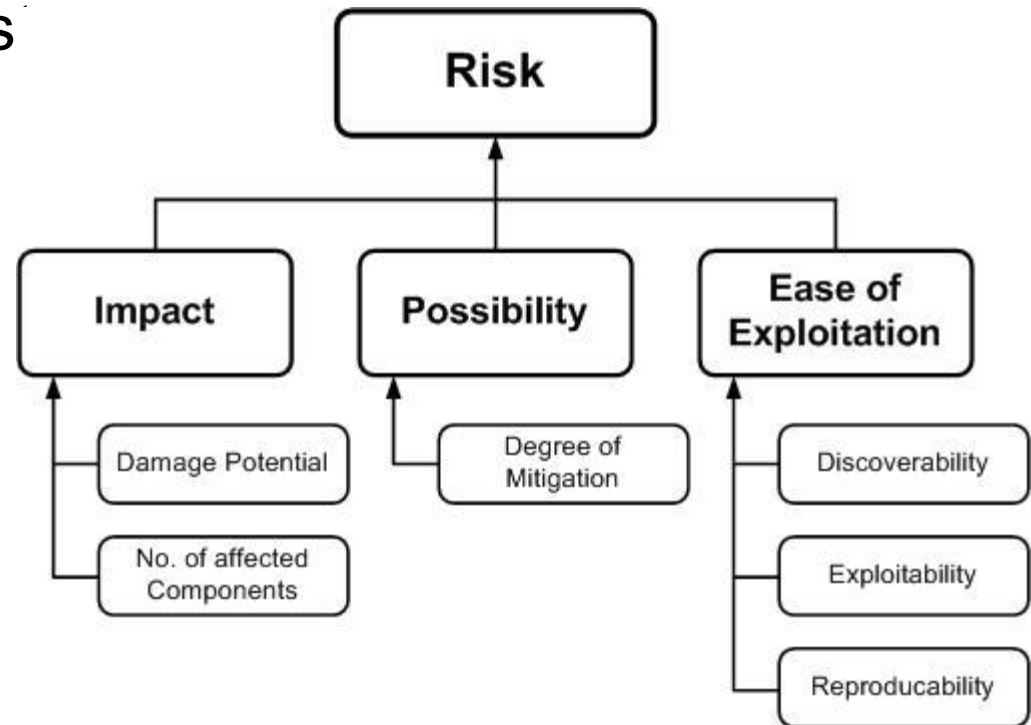
Exposing confidential data

Making a service unavailable

Obtaining unauthorized privileges

Ranking of Threats

- Threats can be ranked from the perspective of risk factors. By determining the risk factor posed by the various identified threats, it is possible to create a prioritized list of threats to support a risk mitigation strategy, such as prioritizing the threats to be mitigated first



STRIDE Threat & Mitigation Techniques

Threat Type	Mitigation Techniques
Spoofing Identity	1. Appropriate authentication 2. Protect secret data 3. Don't store secrets
Tampering with data	1. Appropriate authorization
	2. Hashes
	3. MACs
	4. Digital signatures
	5. Tamper resistant protocols
Repudiation	1. Digital signatures 2. Timestamps 3. Audit trails
Information Disclosure	1. Authorization
	2. Privacy-enhanced protocols
	3. Encryption
	4. Protect secrets
	5. Don't store secrets
Denial of Service	1. Appropriate authentication 2. Appropriate authorization 3. Filtering 4. Throttling 5. Quality of service
Elevation of privilege	1. Run with least privilege

Security Questions for Every Component

- For each component, ask:
- **Data**
 - What data is processed?
 - Is it confidential?
 - Can it be modified?
 - **Access**
- Who can access it?
 - What privileges are required?
 - Is authentication required?
- **Input**
 - What information enters?
 - Is it validated?
 - Can an attacker control it?
- **Output**
 - What information leaves?
 - Could sensitive data be disclosed?
- **Dependencies**
 - Does it rely on another system?
 - What happens if that dependency is compromised?
- **Trust**
 - What level of trust does the component have?
 - Where does trust change?